

Post-Quantum Cryptography Performance, Side-Channel Resilience & Governance Framework:

(Bridging the quantum transition gap through empirical evidence and organizational readiness)

Instructor – Prof. Faisal Kaleem

*(Student- Ishita Bhandari | CYBR 698 Cyber Operations Capstone Project
Cohort 6 | December 2025)
github.com/ibhandari072021/PostQuantumCryptography*

Agenda:

- ▶ **Why Now: Quantum Threat & Migration Urgency**
- ▶ **US Govt Readiness timeline (Ahmed et al. (2025))**
- ▶ **PHASE 1: NIST Develops New Standards (2016–2024)**
- ▶ **PHASE 2: Government Transition Plan (2022–2030)**
- ▶ **Evidence Table – Performance and Mitigation baseline**
- ▶ **Method- Mixed-Methods analysis pipeline**
- ▶ **Standards Alignment: CSF 2.0 & Zero Trust**
- ▶ **Ethics, Data Management and Supply Chain Safeguards**
- ▶ **Evaluation Plan : Metrics and Traceability Chain**
- ▶ **CSF Current → Target profile (SP 1301 approach)**
- ▶ **Reproducibility – One Command Run**
- ▶ **Impact and Next Steps – Research Value and Scalability**
- ▶ **References**

Why Now: Quantum Threat & Migration Urgency

- ▶ **Classical cryptography obsolescence:** Quantum computing (5-10 years forecast) breaks RSA/ECC. Organizations must migrate to NIST-approved PQC before threat maturity.
- ▶ **Sector-specific constraints:** Finance requires sub-millisecond latency, healthcare demands decades-long data integrity, IoT faces resource limits- yet no unified deployment guidance exists.
- ▶ **Governance gap:** Organizations lack framework for compliant, risk-managed PQC transitions aligned with CSF 2.0 and NIST standards.

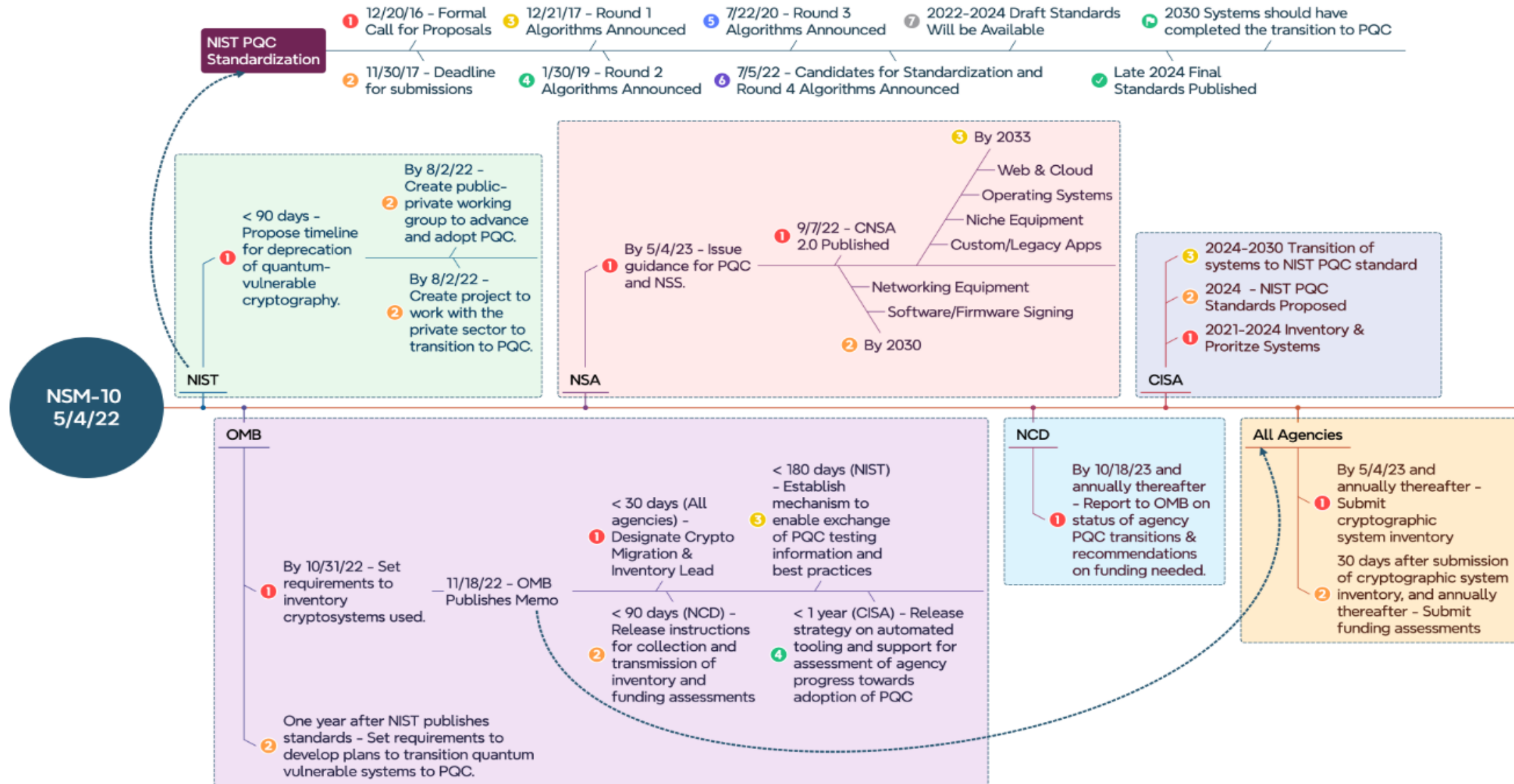
EVIDENCE SNAPSHOT

Study: Ahmed et al. (2025)

Finding: Kyber and Dilithium achieve <30 ms latency in finance; SPHINCS preferred for archival (signature longevity)

Impact: Validates sector-specific algorithm selection

US Govt Readiness timeline (Ahmed et al. (2025))



US Govt Readiness timeline (Ahmed et al. (2025))- Timeline breakdown (2016-2030)

PHASE 1: NIST Develops New Standards (2016-2024)

Date	What Happens	Why
12/2016	NIST calls for new algorithms	Experts worldwide submit PQC ideas
2022	NIST picks finalists (Kyber, Dilithium, SPHINCS)	These are the "winners" that can't be cracked
Late 2024	Standards published officially	Government & industry can now use them

US Govt Readiness timeline (Ahmed et al. (2025))- Timeline breakdown (2016-2030)

PHASE 2: Government Transition Plan (2022-2030)

Agency	Role (simple)	Date / Deadline	Action
NSA	Secures national security systems	May 2022	Says all systems must switch to PQC (post-quantum crypto).
NSA	Secures national security systems	By 2033	Web, cloud, operating systems, devices, and networking equipment must use new PQC encryption.
OMB	Oversees all federal agencies	Oct 2022	Creates an inventory of all encryption systems in use.
OMB	Oversees all federal agencies	Nov 2022	Publishes guidance on how agencies should transition to PQC.
OMB	Oversees all federal agencies	1 year after NIST standards	Requires every agency to have a formal PQC transition plan.
CISA	Protects critical infrastructure	By 2024	Releases tools and support to help agencies migrate to PQC.
CISA	Protects critical infrastructure	By 2030	All critical systems are required to be using PQC.
NCD	Coordinates across agencies	Oct 2023	Reports to leadership on each agency's PQC transition status.
NCD	Coordinates across agencies	Ongoing	Secures and manages funding for PQC transition projects.

Why This Matters To My Research (PQC capstone project)

My capstone project is to study:

- ▶ Performance - Do Kyber, Dilithium, SPHINCS actually work fast enough?
- ▶ Security - Can side-channel attacks break them?
- ▶ Governance - How do organizations plan and manage the transition?

This Govt timeline shows the real pressure organizations face. They have until 2030 to switch, but:

- ▶ Many don't know how (your research helps)
- ▶ Different agencies have different deadlines (confusing)
- ▶ These algorithms are new and not fully tested in production (your evidence table addresses this)

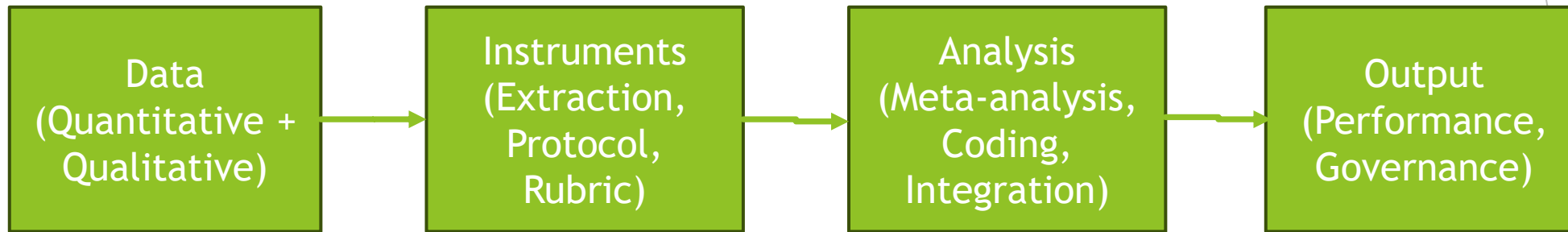
By 2030, all government and critical infrastructure systems must use post-quantum cryptography. My research validates that these three NIST-approved algorithms can actually handle this massive transition without breaking performance, security, or compliance requirements.

Evidence Table: Performance & Mitigation Baseline

Study	Finding	Domain
Ahmed et al. (2025)	Kyber, Dilithium low-latency; SPHINCS for archival	Finance, Healthcare
Boyens (2023)	Masking, constant-time reduce side-channel leakage	Finance, Healthcare pilots
NIST (2024)	Phased rollout, parallel stacks, rollback recommended	Governance, Risk management

Impact: Evidence directly supports RQ-D1 (performance) and RQ-C2 (side-channel mitigation) methodologies; governance findings inform CSF 2.0 alignment and organizational transition strategy.

Method: Mixed Methods analysis pipeline



KEY MEASURES (SMART METRICS):

- 1. SOURCE COVERAGE RATIO** Formula: (unique PQC sources in artifacts) / (total sources cited) Goal: $\geq 80\%$ industry + peer-reviewed coverage Mitigates: Bias risk (800-171r3 03.02.01)
- 2. SIDE-CHANNEL EFFECTIVENESS** Formula: (attack success rate post-mitigation) / (pre-mitigation) Goal: $< 10\%$ residual leakage Validates: RQ-C2 countermeasure impact
- 3. GOVERNANCE ADOPTION RATE** Formula: Organizations implementing phased PQC rollout per NIST guidance Goal: $> 60\%$ of interview cohort Measures: RQ-G1 organizational readiness

STANDARDS ANCHORS - CSF 2.0 & ZERO TRUST (ZTA)

Standard	Outcome/Tenet (Copy-Exact)	Method Alignment
CSF 2.0 (PR.PS, p. 25)	"The hardware, software (e.g., firmware, operating systems, applications, and services) of physical and virtual platforms are managed consistent with the organization's risk strategy to protect their confidentiality, integrity, and availability."	PQC implementation security practices benchmarked; performance logs & vulnerability tracking matrices demonstrate continuous secure software monitoring.
SP 800-207 (Section 3.3.1, p. 16)	"All resource authentication and authorization are dynamic and strictly enforced before access is allowed... Continual monitoring with possible reauthentication and reauthorization occurs throughout user transactions, as defined and enforced by policy."	PQC auth middleware implements session-based MFA; audit logging captures every API request with real-time anomaly detection for continuous reauthentication.

STANDARDS ANCHORS - CSF 2.0 & ZERO TRUST (ZTA)- Evidence

The NIST Cybersecurity ... x Zero Trust Architecture + Create

Convert E-Sign

knowledge and skills to perform general tasks with cybersecurity risks in mind

- **PR.AT-02:** Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind

- **Data Security (PR.DS):** Data are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information
 - **PR.DS-01:** The confidentiality, integrity, and availability of data-at-rest are protected
 - **PR.DS-02:** The confidentiality, integrity, and availability of data-in-transit are protected
 - **PR.DS-10:** The confidentiality, integrity, and availability of data-in-use are protected
 - **PR.DS-11:** Backups of data are created, protected, maintained, and tested

- **Platform Security (PR.PS):** The hardware, software (e.g., firmware, operating systems, applications), and services of physical and virtual platforms are managed consistent with the organization's risk strategy to protect their confidentiality, integrity, and availability
 - **PR.PS-01:** Configuration management practices are established and applied
 - **PR.PS-02:** Software is maintained, replaced, and removed commensurate with risk
 - **PR.PS-03:** Hardware is maintained, replaced, and removed commensurate with risk
 - **PR.PS-04:** Log records are generated and made available for continuous monitoring
 - **PR.PS-05:** Installation and execution of unauthorized software are prevented
 - **PR.PS-06:** Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle

- **Technology Infrastructure Resilience (PR.IR):** Security architectures are managed with the organization's risk strategy to protect asset confidentiality, integrity, and availability, and organizational resilience
 - **PR.IR-01:** Networks and environments are protected from unauthorized logical access and usage

20

Zero Trust Architecture x + Create

Find text or tools 🔍 🗂️ ↺️ 🖨️

NIST SP 800-207 ZERO TRUST ARCHITECTURE

network location, time, reported active attacks, etc. These rules and attributes are based on the needs of the business process and acceptable level of risk. Resource access and action permission policies can vary based on the sensitivity of the resource/data. Least privilege principles are applied to restrict both visibility and accessibility.

5. **The enterprise monitors and measures the integrity and security posture of all owned and associated assets.** No asset is inherently trusted. The enterprise evaluates the security posture of the asset when evaluating a resource request. An enterprise implementing a ZTA should establish a continuous diagnostics and mitigation (CDM) or similar system to monitor the state of devices and applications and should apply patches/fixes as needed. Assets that are discovered to be subverted, have known vulnerabilities, and/or are not managed by the enterprise may be treated differently (including denial of all connections to enterprise resources) than devices owned by or associated with the enterprise that are deemed to be in their most secure state. This may also apply to associated devices (e.g., personally owned devices) that may be allowed to access some resources but not others. This, too, requires a robust monitoring and reporting system in place to provide actionable data about the current state of enterprise resources.
6. **All resource authentication and authorization are dynamic and strictly enforced before access is allowed.** This is a constant cycle of obtaining access, scanning and assessing threats, adapting, and continually reevaluating trust in ongoing communication. An enterprise implementing a ZTA would be expected to have Identity, Credential, and Access Management (ICAM) and asset management systems in place. This includes the use of multifactor authentication (MFA) for access to some or all enterprise resources. Continual monitoring with possible reauthentication and reauthorization occurs throughout user transactions, as defined and enforced by policy (e.g., time-based, new resource requested, resource modification, anomalous subject activity detected) that strives to achieve a balance of security, availability, usability, and cost-efficiency.
7. **The enterprise collects as much information as possible about the current state of assets, network infrastructure and communications and uses it to improve its security posture.** An enterprise should collect data about asset security posture, network traffic and access requests, process that data, and use any insight gained to improve policy creation and enforcement. This data can also be used to provide context for access requests from subjects (see Section 3.3.1).

The above tenets attempt to be technology agnostic. For example, "user identification (ID)" could include several factors such as username/password, certificates, and onetime password. These tenets apply to work done within an organization or in collaboration with one or more partner organizations and not to anonymous public or consumer-facing business processes. An

This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-207>

Ethics, Data Management & Supply Chain Safeguards

- ▶ **Privacy & Confidentiality:** De-identification (pseudonyms, removal of identifiers), AES-256 encryption at rest/transit, least-privilege access (quarterly reviews), secure erasure post-retention (5 years). *Mitigates:* Re-identification, parameter leakage risks (Week 7).
- ▶ **Data Handling:** Git versioning with checksums, Jupyter transformation logs, encrypted S3 backups. Sensitive data (interviews, test logs) not shared; aggregated results published. *Reference:* DMP.md
- ▶ **Supplier Risk (PQC Libraries):** Open-source Kyber/Dilithium/SPHINCS tracked via SBOM (Software Bill of Materials) with checksums; proactive vulnerability monitoring in CI/CD. *Reference:* docs/cSRM_note.md
- ▶ **Control Mapped:** AU-2 (Audit Events) - SP 800-53 Rev.5 - organization-defined event logging for privacy incident detection and accountability.

Evaluation Plan: Metrics & Traceability Chain

Risk → Requirement → Metric → Evidence

- ▶ **Example Chain (Week 11):**
Risk: Insufficient PQC performance metrics → *Requirement (800-171r3 03.02.01):* Establish baseline of security-relevant data sources → *Metric:* Source Coverage Ratio = (unique PQC sources) / (total cited)
→ *Evidence:* docs/sourcecount.csv (weekly update post-literature search)
- ▶ **SMART Metrics (Week 11 Artifact)**

SMART Metrics (Week 11 Artifact)		
Metric Name	Formula / Definition	Data Source
Source Coverage	Unique PQC sources / Total sources	docs/sourcecount.csv
Reference Freshness	Avg. publication year (goal: >75% post-2023)	docs/sourcelog.csv
Privacy Incident Rate	Leaked test runs / Total test runs	docs/logs/testoutput.log

CSF CURRENT → TARGET PROFILE (SP 1301 GOVERNANCE APPROACH)

Organizational Cryptographic Maturity

Outcome 1: PR.DS (Data Security, p. 25)

Current: Organizations manage classical RSA/ECC with manual key lifecycle; de facto monitoring of cryptographic operations.

Target: NIST PQC algorithms (Kyber, Dilithium, SPHINCS) deployed with automated key management; real-time monitoring of cryptographic events and side-channel anomalies operationalized.

Outcome 2: PR.PS (Platform Security, p. 25)

Current: Legacy cryptographic libraries; inconsistent version tracking; ad-hoc patching cycles.

Target: SBOM-tracked PQC implementations; continuous vulnerability scanning (CI/CD); proactive patch management per NIST SP 800-161r1 supply chain guidance.

Data are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information."(CSF 2.0, Appendix A, PR.DS, p. 25)

Reproducibility

From Week 9 Docker Assignment: *docker build -t pqcdev . && docker run --rm -v \$(pwd):work pqcdev*

1. `docker build -t pqcdev .`

Builds Docker image named "pqcdev"

Includes: Python 3.11, pandas, analysis scripts

Creates reproducible environment (no local dependency conflicts)

2. `docker run --rm -v $(pwd):/work pqcdev`

Runs container from pqcdev image \

Mounts current project directory as /work inside container

Executes analysis pipeline

--rm flag removes container after execution (clean system)

Anyone can run this exact command and produce identical results, regardless of local Python/library versions. Guarantees transparency and scientific rigor in capstone research.

Output Files Generated (in docs/):

1. docs/latencybyalgorithm.txt Average execution time (ms) by PQC algorithm Evidence for RQ-D1:

Performance metrics across sectors

2. docs/attackratebysector.txt Attack success rate (%) by organizational sector Evidence for RQ-C2:

Side-channel risk quantification

IMPACT & NEXT STEPS - RESEARCH VALUE & SCALABILITY

Research Impact: Provides empirical evidence for PQC deployment across three critical sectors; fills governance gap in industry standards integration.

Organizational Value: Delivers CSF 2.0-aligned migration roadmap, risk-managed transition playbook, and sector-specific algorithm recommendations.

Scalability: Reproducible methodology enables adoption by CISA, NSA, and private organizations managing quantum-resistant cryptography transitions.

SCALABILITY & NEXT STEPS:

This reproducible methodology enables adoption by:

- CISA and NSA for quantum readiness initiatives
- Private organizations managing PQC transitions
- Government agencies aligning with NIST standards

Future work: Expand qualitative cohort - more interviews. Review more research papers, publish findings in peer-reviewed venue (IEEE, ACM, NIST Journal). contribute through blogs , articles related to PQC.

FULL PROJECT REPOSITORY:

<https://github.com/ibhandari072021/PostQuantumCryptography>

The screenshot displays the GitHub interface for the repository `ibhandari072021 / PostQuantumCryptography`. The left sidebar shows the file tree with the following structure:

- main
- DMP
- cSRM
- docs
 - logs
 - pitch
 - CYBR698_CapstoneProject_Pre...
 - CYBR698_CapstoneProject_Pre...
 - Smart Metrics.pdf
 - Traceability Metrics.pdf
 - access_control_policy.md
 - access_log.md
 - consent_script.md
 - crosswalk.md
 - experiment_manifest.txt
 - image.png
 - peerreview_log.txt
 - privacy_program_plan.md
 - redaction_rules.txt
 - search_log.txt
 - source_count.csv
 - source_log.csv

The main content area shows the file `PostQuantumCryptography / docs / pitch / CYBR698_CapstoneProject_Presentation.pdf`. The file is 664 KB and was updated by `ibhandari072021` 15 minutes ago. The PDF content is a presentation slide titled "Post-Quantum Cryptography Performance, Side-Channel Resilience & Governance Framework: (Bridging the quantum transition gap through empirical evidence and organizational readiness)". The slide also mentions the instructor, Prof. Faisal Kaleem, and the student, Ishita Bhandari, who is a member of the CYBR 698 Cyber Operations Capstone Project Cohort 6, December 2025. The GitHub repository URL is provided at the bottom of the slide.

11:24 PM
12/7/2025

References

- [1] C. K. Gitonga, “The Impact of Quantum Computing on Cryptographic Systems: Urgency of Quantum-Resistant Algorithms and Practical Applications in Cryptography,” *European Journal of Information Technologies and Computer Science*, vol. 5, no. 1, pp. 1–10, Jan. 2025, doi: 10.24018/COMPUTE.2025.5.1.146.
- [2] E. D. Demir, B. Bilgin, M. Cengiz, and O. Onbas, “Performance Analysis and Industry Deployment of Post-Quantum Cryptography Algorithms,” Mar. 2025, Accessed: Sep. 07, 2025. [Online]. Available: <https://arxiv.org/pdf/2503.12952v1>
- [3] “NIST Releases First 3 Finalized Post-Quantum Encryption Standards | NIST.” Accessed: Sep. 08, 2025. [Online]. Available: <https://www.nist.gov/news-events/news/2024/08/nist-releases-first-3-finalized-post-quantum-encryption-standards>
- [4] N. Institute of Standards, “The NIST Cybersecurity Framework (CSF) 2.0,” 2024, doi: 10.6028/NIST.CSWP.29.
- [5] F. Erata, Y. University, V. Mateu, and J. Szefer, “Towards Automated Detection of Single-Trace Side-Channel Vulnerabilities in Constant-Time Cryptographic Code Ruzica Piskac”, Accessed: Dec. 06, 2025. [Online]. Available: <https://github.com/ferhaterata/pascal>
- [6] J. M. Boyens, “Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations,” 2024. doi: 10.6028/NIST.SP.800-161r1-upd1.
- [7] N. Ahmed, L. Zhang, and A. Gangopadhyay, “A Survey of Post-Quantum Cryptography Support in Cryptographic Libraries,” Aug. 2025, Accessed: Sep. 27, 2025. [Online]. Available: <https://arxiv.org/pdf/2508.16078v1>
- [8] “(23) Comprehensive Analysis of Kyber, Dilithium, and SPHINCS+: Pros, Cons, Use Cases, and Implementations in Post-Quantum Cryptography | LinkedIn.” Accessed: Sep. 27, 2025. [Online]. Available: <https://www.linkedin.com/pulse/comprehensive-analysis-kyber-dilithium-sphincs-pros-cons-epure-umvcf/>
- [9] “NIST Releases First 3 Finalized Post-Quantum Encryption Standards | NIST.” Accessed: Sep. 27, 2025. [Online]. Available: <https://www.nist.gov/news-events/news/2024/08/nist-releases-first-3-finalized-post-quantum-encryption-standards>
- [10] “Inside NIST’s PQC: Kyber, Dilithium, and SPHINCS+.” Accessed: Sep. 27, 2025. [Online]. Available: <https://postquantum.com/post-quantum/nists-pqc-technical/>

Thank you

The background features a large, abstract geometric design on the right side. It consists of several overlapping triangles and polygons in various shades of green, ranging from a light lime green to a dark forest green. The design is set against a white background on the left, where the text 'Thank you' is located.